

Subnets

Public vs Private

BaseStack Academy · AWS Cloud Accelerator

Networking & VPC

Cohort 1

Beginner-Friendly

SAA-C03 Aligned

 PUBLIC	 PRIVATE
Internet Gateway route 0.0.0.0/0 → igw-xxx	NAT Gateway route or no internet route
Load Balancer	EC2 App Servers
Bastion Host	RDS Databases
NAT Gateway	ElastiCache
Public / Elastic IP	No public IP

1 Overview — The Decision That Defines Your Security Posture

FOUNDATION

2 Key Concepts — Subnet Types, CIDRs, and Reserved IPs

CORE KNOWLEDGE

3 Default vs Custom Subnets — What AWS Creates and Why It's Dangerous

DEEPER LEARNING

4 How It Works — Sizing, Planning, and Route Association

MECHANICS

5 Technical Deep Dive — Multi-AZ CIDR Planning & Tier Isolation

ADVANCED DETAIL

6 Architecture & Visual Model — 3-Tier HA Subnet Layout

VISUAL

7 Real-World Nigerian Scenario

CONTEXT

8 Common Mistakes & Exam Traps

EXAM PREP

Overview — The Decision That Defines Your Security Posture

On Day 1, we created a VPC and established the outer boundary of our private network. Today we go one level deeper — into subnets.

A subnet is the specific slice of your VPC's IP space where your actual resources live. Every EC2 instance, every RDS database, every Lambda function with a VPC attachment, every container in ECS — all of them must be placed in a specific subnet. The subnet you choose determines: whether the resource has a path to the internet, what security controls apply at the network layer, which Availability Zone the resource sits in, and whether the resource is reachable from outside your VPC at all.

The public/private subnet decision is the most fundamental architectural choice you make when deploying any application on AWS. Getting it wrong means either exposing internal services to the internet unnecessarily, or building unnecessary complexity to work around a misconfigured network.

WHY NOW?

Every cloud security breach where production databases were exposed traces back to one decision: placing them in a public subnet, or allowing a misconfigured public route into a private subnet.

Nigerian financial regulators — CBN and SEC — require that financial data backends (databases, processing engines, key management systems) must be in private subnets with no direct internet route, provably enforced at the network routing layer.

SAA-C03 Domain 1 and Domain 2 both test subnet design — specifically which tier belongs in which subnet, and why routing (not naming) determines subnet type.

Beginner Note

A subnet is like a specific floor in a building. The VPC is the building. Public subnets are the ground floor with a reception that anyone can visit. Private subnets are the secure upper floors — accessible only to those who first came through reception.



Key Concepts — Subnet Types, CIDRs & Reserved IPs



Study tip: Every concept here connects directly to a routing or security behaviour. Understand the mechanism, not just the definition.

Public Subnet

A subnet whose route table contains a route pointing 0.0.0.0/0 (all internet traffic) to an Internet Gateway. Resources in a public subnet CAN communicate directly with the internet — provided they also have a public or Elastic IP address. Public subnets host internet-facing resources: load balancers, bastion hosts, NAT gateways.

Private Subnet

A subnet whose route table has NO direct route to an Internet Gateway. Resources here are isolated from inbound internet traffic by design — not by Security Group rules alone. Private subnets may have a NAT Gateway route for outbound access, or no internet route at all (fully isolated). Application servers, databases, and caches belong here.

Auto-Assign Public IP

A subnet-level setting that automatically assigns a public IPv4 address to every EC2 instance launched in that subnet. Enabled by default in the Default VPC. Should be DISABLED in all custom subnets — especially private ones. Note: an auto-assigned public IP is NOT the same as an Elastic IP — it changes every stop/start cycle.

Subnet CIDR Block

The IP address range assigned to a subnet — must be a subset of the VPC's CIDR. Example: if the VPC is 10.0.0.0/16, a subnet can be 10.0.1.0/24. Each subnet needs a non-overlapping CIDR. The smaller the prefix number ($/16 > /24 > /28$), the more addresses available.

The 5 Reserved IPs

AWS reserves 5 IP addresses in EVERY subnet, regardless of size: .0 = Network address, .1 = VPC router, .2 = DNS server, .3 = Future use (reserved by AWS), .255 = Broadcast. A /24 subnet (256 total) has 251 usable. A /28 (16 total) has only 11 usable. Always factor this into subnet sizing decisions.

Subnet AZ Binding

Every subnet is bound to exactly ONE Availability Zone at creation — this cannot be changed. A subnet cannot span AZs. For High Availability, you must create separate subnets in each AZ and deploy resources across them. This is the mechanism behind AWS's multi-AZ resilience pattern.



Default vs Custom Subnets — What AWS Creates and Why It Matters

Every AWS account has a Default VPC with Default Subnets pre-created. Understanding the difference — and why you should NEVER use the Default VPC for production — is critical.



Default VPC & Default Subnets

Created automatically

When you first create an AWS account, AWS creates one Default VPC per Region (172.31.0.0/16) with one Default Subnet per Availability Zone.

Default Subnets are PUBLIC

Every Default Subnet has Auto-Assign Public IP enabled and a route table pointing to an Internet Gateway. Any EC2 you launch gets a public IP immediately — even if you didn't intend it.

CIDR is fixed

172.31.0.0/16 with /20 subnets. You cannot choose. You cannot redesign it. The IP range may conflict with corporate VPNs or other networks you want to peer with.

No network segmentation

There is no public/private separation. All subnets are equivalent. All resources are equally exposed. This violates every serious security requirement.

Fine for learning — dangerous for production

Acceptable for quick experiments and demos. Never for real workloads, regulated environments, or anything that holds customer data.



Custom VPC & Custom Subnets

You design the CIDR

Choose your VPC CIDR (e.g., 10.0.0.0/16) with growth in mind. Design subnet ranges that fit your architecture. Non-overlapping, planned from day one.

Subnets are PRIVATE by default

A new custom subnet has no route to an Internet Gateway until you explicitly add one. Auto-Assign Public IP is disabled by default. Nothing is exposed unless you intentionally configure it.

You control the tier structure

Explicitly create public subnets for load balancers, private subnets for app servers, and isolated subnets for databases. Each tier has its own route table with appropriate routing.

Full compliance capability

With custom subnets, you can demonstrably prove network segmentation to CBN, SEC, or any auditor — by showing route tables with no internet routes on data tier subnets.

Industry standard for all production workloads

Every serious AWS deployment — every bank, every fintech, every enterprise — uses a custom VPC. The Default VPC is a convenience for learning, not a production tool.

How It Works — Sizing, Planning & Route Table Association

1

Plan Your Subnet Layout Before Creating Anything

Before opening the console, answer these questions: How many tiers do you need? (Public, Private-App, Private-Data are the standard three.) How many AZs? (Two minimum for HA, three for critical workloads.) What CIDR per subnet? For most cases, /24 gives 256 IPs (251 usable) — enough for any single-tier, single-AZ workload. For larger tiers like a fleet of 200 EC2 instances, use /22 (1024 total, 1019 usable). Draw a table: Subnet name | AZ | CIDR | Tier | Route table. Fill it in before any console clicks.

2

Create Subnets and Associate Route Tables

In the VPC console: Subnets → Create Subnet. For each subnet: assign a name (be descriptive — e.g., prod-public-az1a), select the VPC, select the specific AZ, and enter the CIDR block. Repeat for every subnet in your plan.

Then critically — route table association. Subnets are not public or private by themselves. They become public when you associate them with a route table that contains 0.0.0.0/0 → Internet Gateway. Associate your public subnets with the public route table. Associate your private-app subnets with the private route table (0.0.0.0/0 → NAT Gateway). Associate your data tier subnets with the isolated route table (local route only — no internet entry).

3

Configure NACL and Verify Auto-Assign Settings

Each subnet gets a NACL applied — by default, the VPC's default NACL (which allows everything). For data tier subnets, consider creating a custom NACL with explicit deny rules — blocking all traffic except the specific ports your application uses (e.g., port 5432 for PostgreSQL from the app subnet CIDR only).

Also verify: for all private subnets, confirm 'Auto-Assign Public IPv4 Address' is set to NO. For public subnets hosting instances that need public IPs, set it to YES. Never leave this unchecked — an accidentally public EC2 instance in what you thought was a private subnet is a common and serious misconfiguration.



Technical Deep Dive — Multi-AZ CIDR Planning & Tier Isolation

Multi-AZ CIDR Planning — Production Example (10.0.0.0/16 VPC)

Subnet Name	AZ	CIDR	IPs	Tier	Route Table
prod-public-az1a	eu-west-1a	10.0.1.0/24	251	Public	public-rt
prod-public-az1b	eu-west-1b	10.0.2.0/24	251	Public	public-rt
prod-app-az1a	eu-west-1a	10.0.11.0/24	251	Private-App	private-app-rt
prod-app-az1b	eu-west-1b	10.0.12.0/24	251	Private-App	private-app-rt
prod-data-az1a	eu-west-1a	10.0.21.0/24	251	Private-Data	isolated-rt
prod-data-az1b	eu-west-1b	10.0.22.0/24	251	Private-Data	isolated-rt
prod-mgmt-az1a	eu-west-1a	10.0.100.0/24	251	Management	mgmt-rt
prod-mgmt-az1b	eu-west-1b	10.0.101.0/24	251	Management	mgmt-rt

💡 Numbering convention: Public=10.0.1-9.x, App=10.0.10-19.x, Data=10.0.20-29.x, Mgmt=10.0.100+.
This makes subnets instantly identifiable by IP range.

Subnet Isolation — What Each Tier Allows

PUBLIC TIER

Route: 0.0.0.0/0 → IGW
10.0.0.0/16 → local

SG: Allow 443 (HTTPS) from 0.0.0.0/0
Allow 80 from 0.0.0.0/0

NACL: Allow inbound 80, 443, 1024-65535
Deny all else

PRIVATE-APP TIER

Route: 0.0.0.0/0 → NAT GW
10.0.0.0/16 → local

SG: Allow 8080 from Public SG only
Allow 443 outbound

NACL: Allow inbound from public CIDR
Deny direct internet inbound

PRIVATE-DATA TIER

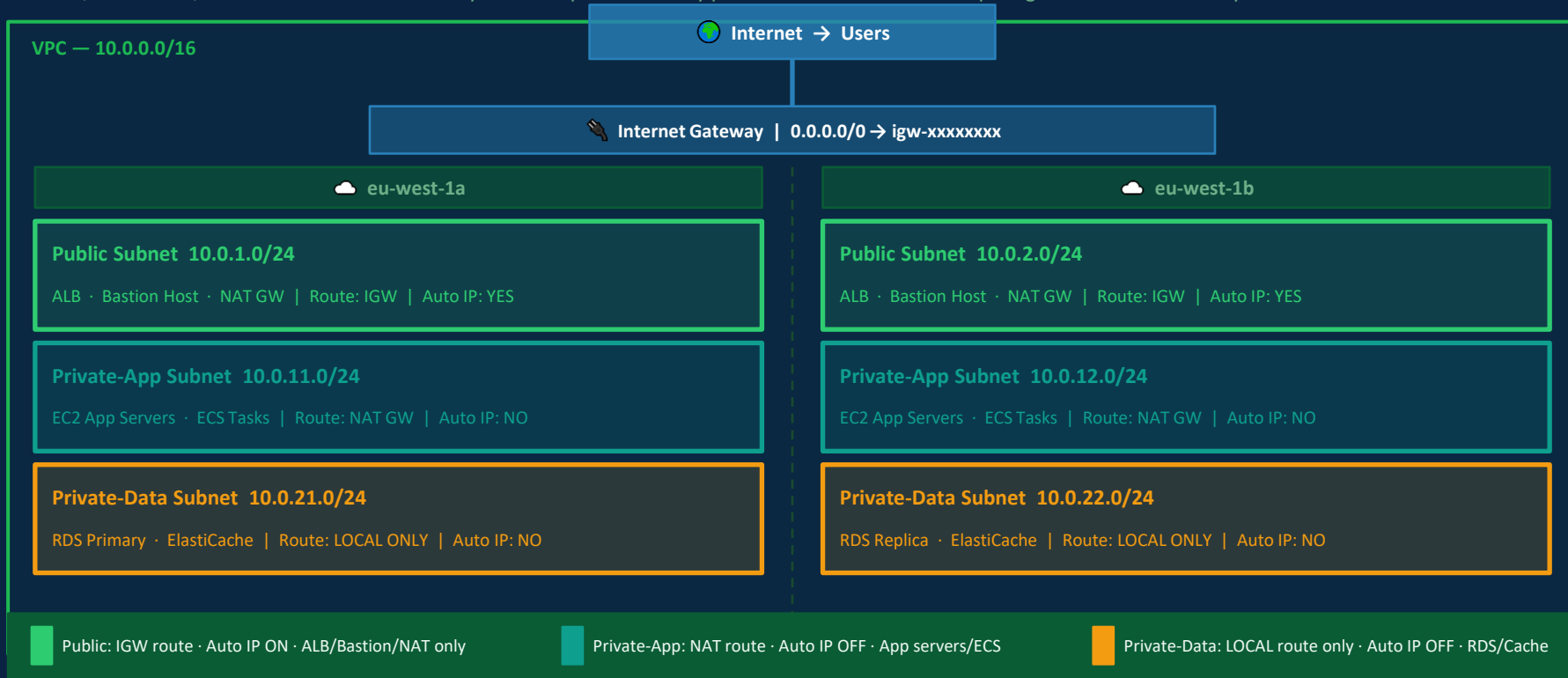
Route: 10.0.0.0/16 → local ONLY
No 0.0.0.0/0 entry

SG: Allow 5432 from App SG only
Deny all other inbound

NACL: Allow inbound from app CIDR only
Deny all internet traffic

Architecture — 3-Tier High-Availability Subnet Layout

Two AZs, six subnets, three tiers. This is the industry-standard pattern for any production AWS workload requiring resilience and security.





Real-World Nigerian Scenario — Flutterwave-Style Payment Gateway

SCENARIO:

A Nigerian fintech company — modelled on Flutterwave's architecture — processes card payments for merchants across West Africa. Their infrastructure handles PCI-DSS cardholder data, is subject to CBN's Payment System Management regulations, and processes an average of 4 million transactions per day. Their security team has been tasked with designing a compliant subnet architecture before the next CBN IT examination.



Subnet Design Decisions & Regulatory Justification

Public Subnets: ONLY the API Gateway and Load Balancer

Only two resource types are allowed in public subnets: the AWS Application Load Balancer that receives merchant API calls, and the AWS WAF (Web Application Firewall) in front of it. No EC2 instances. No application logic. No data access. The PCI-DSS requirement is that cardholder data processing must never occur in the same network segment as internet-facing components. Public subnets are therefore cardholder data-free zones.

Private-App Subnets: Payment Processing Microservices

All transaction processing, fraud detection, routing logic, and merchant management services run in private-app subnets. These services call external card networks (Visa, Mastercard) via the NAT Gateway — outbound only. No inbound internet path exists. Security Groups allow inbound only from the Load Balancer's Security Group on port 443. Engineers access these instances via the Bastion Host in the public subnet — never directly.

Private-Data Subnets: Completely Isolated — No NAT Route

RDS PostgreSQL (encrypted at rest with KMS) and ElastiCache Redis (session tokens) live in private-data subnets with route tables containing ONLY the local VPC route. No NAT Gateway route. No management access path. The CBN Payment System Management framework explicitly requires cardholder data to be stored in systems with no direct or indirect internet connectivity. The route table is the audit evidence — it is inspectable and tamper-evident.

Management Subnet: /28 for Bastion Hosts Only

A small /28 management subnet (10.0.100.0/28 — 11 usable IPs) exists in one AZ. It hosts two Bastion Host EC2 instances in an Auto Scaling group. Security Groups on the Bastion allow SSH (port 22) only from the company's Lagos office static IP and the CISO's home IP. All Bastion sessions are logged via AWS Systems Manager Session Manager to S3 for regulatory audit. No other resource type is allowed in this subnet — enforced by the NACL blocking all non-SSH traffic.



Discussion: The PCI-DSS standard requires that cardholder data systems be isolated from the internet. A developer suggests using a Security Group (denying all inbound) instead of a private subnet. Why is this architecturally insufficient — even if the Security Group is correctly configured?



Common Mistakes & Exam Traps

● These are the most common SAA-C03 exam errors on subnets — every one costs marks.



TRAP 1: A subnet is public because of its ROUTE TABLE — NOT because of its name, Auto-Assign IP setting, or any other attribute.

The exam LOVES this trap. 'A subnet named PublicSubnet-AZ1 has Auto-Assign Public IP enabled, but EC2 instances in it cannot reach the internet. Why?' Answer: the route table has no route to an Internet Gateway. Publicness is determined ONLY by the route table. Name, Auto-Assign, and Security Groups are irrelevant to determining public vs private status. Routing is everything.



TRAP 2: Subnets are tied to ONE AZ. They cannot span AZs. VPCs span all AZs in a Region.

Exam questions describe a 'subnet spanning multiple AZs' — this is never possible. Subnets are created in exactly one AZ at creation time and cannot be changed. For multi-AZ resilience, create separate subnets in each AZ. A VPC, however, is Regional and automatically spans all AZs in the Region. Know the distinction: VPC = Regional. Subnet = single AZ.



TRAP 3: A /24 subnet has 251 usable IPs — not 256. AWS reserves 5 per subnet.

The reserved 5: .0 (network), .1 (VPC router), .2 (DNS), .3 (AWS future use), .255 (broadcast). This is directly tested — 'A customer needs 250 EC2 instances in a single subnet. They create a /24 subnet. Will this work?' Answer: No. /24 = 256 total, 251 usable — less than 250. Use /23 (512 total, 507 usable) instead. Miscalculating subnet capacity is a common exam error in architecture design questions.



TRAP 4: The Default VPC's Default Subnets are ALL public — they have Auto-Assign IP enabled and routes to the IGW.

Many candidates assume the Default VPC is secure by default. It is not. Every Default Subnet in every AZ has a route table entry pointing to an Internet Gateway and Auto-Assign Public IP enabled. Any EC2 you launch in the Default VPC gets a public IP and is internet-accessible unless a Security Group blocks it. Never use the Default VPC for production, regulated workloads, or any environment that holds real customer data.



TRAP 5: A Security Group alone cannot make a public subnet private — it cannot remove the route table entry to the IGW.

If a subnet's route table has 0.0.0.0/0 → IGW, that subnet is architecturally public regardless of Security Group rules. A Security Group can prevent traffic from reaching specific instances, but the subnet still has a public routing path. For compliance purposes, regulatory auditors require the route table to have NO internet entry — not just a Security Group claiming to block it. Route table = architecture. Security Group = operational control.



Question

A solutions architect is designing a three-tier application on AWS for a Lagos financial services company. The web tier serves public user traffic, the application tier processes business logic, and the data tier stores customer financial records. The company's compliance team requires that the data tier must have NO path to the internet, even for outbound traffic, and this must be enforceable at the network layer — not just the application layer. Which combination of configurations meets ALL requirements? (Select TWO)

A

Place the data tier in a private subnet. Configure a Security Group on the RDS instances that denies all inbound and outbound traffic from 0.0.0.0/0.

Wrong. A Security Group is an application-layer control. The subnet may still have a route to the internet (via NAT or IGW). The compliance team requires network-layer enforcement — which means the route table must have no 0.0.0.0/0 entry, not just a Security Group rule.

B

Place the data tier in a private subnet with a route table that contains ONLY the local VPC route (10.0.0.0/16 → local). Do not add a NAT Gateway route to this route table.

✓ CORRECT

Correct. A route table with only the local VPC entry means there is no path to the internet in any direction — no IGW route, no NAT Gateway route. This is provable at the network architecture layer, satisfying compliance requirements for financial data isolation.

C

Place the web tier EC2 instances and the Application Load Balancer in the same public subnet to simplify the architecture.

Wrong. EC2 web tier instances should be in a private subnet — the ALB in the public subnet forwards traffic to them. Placing EC2 instances in a public subnet unnecessarily exposes them. The ALB handles internet exposure; the web tier EC2 should be private.

D

Place the application tier in a private subnet with a NAT Gateway route for outbound-only internet access. Ensure no route to the Internet Gateway exists on this subnet.

✓ CORRECT

Correct. Application tier servers need outbound internet access to call external services (e.g., payment networks, SMS providers). A NAT Gateway route enables this while preventing all inbound internet connections — the standard pattern for a private-app subnet.

E

Configure a Network ACL on the data tier subnet that denies all traffic with a source or destination of 0.0.0.0/0. Leave the route table with a NAT Gateway route.

Wrong. A NACL can block traffic, but the route table still has a path to the internet (via NAT Gateway). If the NACL is ever misconfigured, the internet path exists. Compliance requires the route table itself to have no internet route — defence in depth means removing the path entirely, not just blocking it.

💡 Key Takeaways — What You Learned Today

Subnets — Public vs Private

✅ Concepts Covered

- ✓ Public subnet = route table has 0.0.0.0/0 → IGW. Nothing else makes it public.
- ✓ Private subnet = no direct IGW route. May have NAT GW for outbound only.
- ✓ Isolated subnet = local VPC route ONLY. Zero internet path in either direction.
- ✓ Default VPC subnets are ALL public — never use for production workloads.
- ✓ Custom subnets are private by default — publicness must be explicitly configured.
- ✓ 5 IPs reserved per subnet: .0 .1 .2 .3 .255 — always subtract from total.
- ✓ Subnets are single-AZ. For HA: create subnets in each AZ, deploy across them.
- ✓ Auto-Assign Public IP must be disabled on all private subnets.
- ✓ Route table is the compliance evidence — not Security Group rules.
- ✓ Management tier: small /28 subnet for bastion hosts with session logging.

📋 Before Next Class

1. Recall all 10 concepts above without notes — active retrieval first
2. Console lab: create 6 subnets in a custom VPC — 2 public, 2 private-app, 2 private-data, across 2 AZs
3. Create 3 route tables (public-rt, private-rt, isolated-rt) and associate the correct subnets to each
4. Verify Auto-Assign Public IP is OFF on all private/data subnets, ON on public subnets
5. Launch an EC2 in each of your private subnets — confirm no public IP is assigned
6. Write down the 5 reserved IPs per subnet from memory — without referencing notes
7. Draw the 6-subnet layout from this lesson on paper, labelling every CIDR and route table



Further Resources & Reading

Go deeper with these official AWS and industry resources:



Amazon VPC — Subnets Documentation

OFFICIAL DOCS

<https://docs.aws.amazon.com/vpc/latest/userguide/configure-subnets.html>

Complete reference for subnet creation, CIDR allocation, AZ binding, route table association, NACL attachment, and the Default VPC structure. The 'Subnet sizing for IPv4' section explains the 5 reserved IPs and how to calculate usable hosts.



AWS VPC Subnet Sizing Guide — IP Address Planner

PLANNING TOOL

<https://docs.aws.amazon.com/vpc/latest/userguide/subnet-sizing.html>

AWS's own guidance on subnet sizing for both IPv4 and IPv6. Covers the minimum viable subnet size for EKS node groups (/28), ECS tasks, and RDS deployments. Includes subnet sizing considerations for future growth — critical for enterprise VPC design.



AWS Security Best Practices — Subnet Isolation Patterns

SECURITY

<https://docs.aws.amazon.com/vpc/latest/userguide/vpc-security-best-practices.html>

Official AWS guidance on subnet security including: keeping resources in private subnets, using layered security (SG + NACL + routing), isolating database subnets from internet routing, and enabling VPC Flow Logs for subnet-level traffic visibility.



VPC Flow Logs — Monitoring Subnet Traffic

OPERATIONAL

<https://docs.aws.amazon.com/vpc/latest/userguide/flow-logs.html>

VPC Flow Logs capture metadata about traffic accepted and rejected at subnet and ENI level. Essential for security auditing, compliance reporting (CBN, PCI-DSS), and debugging network connectivity issues. Can be delivered to CloudWatch Logs or S3. This is your CloudTrail equivalent for network traffic.



SAA-C03 Domain 2 — Secure Subnet Architecture

EXAM PREP

https://d1.awsstatic.com/training-and-certification/docs-sa-assoc/AWS-Certified-Solutions-Architect-Associate_Exam-Guide.pdf

Download the exam guide. Domain 2, Task Statement 2.2 covers designing secure network architectures — specifically which resource types belong in which subnet tier, how route tables enforce security isolation, and the difference between Security Group and NACL layers.



Homework: Read at least ONE resource above before next class. Post what you learned on the WhatsApp group.



Week 3 · Day 2 Complete

Subnets — Public vs Private

Networking & VPC

Next: Hands-on Console Lab →

basestack.academy · Cohort 1 · AWS Cloud Accelerator